

TP1, eleve : Recon & cartographie (HARD MODE)

- Jour 1 - Duree : ~1h30 - Dossier : `jour1-recon/`
- Posture : OFFENSIVE (observation + correlation), on n'exploite pas encore

Contexte

Cette cible ne donne rien gratuitement. Pas de liste d'endpoints, pas de flag pose en evidence. Le flag final ne se trouve nulle part en entier : il s'ASSEMBLE a partir de **3 fragments** caches a des endroits differents, chacun au bout d'une chaine de decouverte.

Objectif

Reconstituer et valider :

```
HUMANIX{recon_<fragment1>_<fragment2>_<fragment3>}
```

Mise en place

```
cd jour1-recon
docker compose up -d --build
```

- Cible : `http://localhost:8001` - Scoreboard : `http://localhost:8001/scoreboard`

Perimetre

- Uniquement localhost:8001 et ses vhosts locaux.
- La cible RALENTIT le fuzzing aveugle (tarpit sur trop de 404). Visez juste : liste ciblee, pas un dictionnaire de 100k lance a l'aveugle.

Deroule guide (3 chaines a reconstituer)

Vous devez trouver 3 fragments. On ne vous dit ni ou ni comment ; voici seulement les axes a creuser.

1. **Artefacts de developpement** : un dev a-t-il versionne quelque chose par erreur ? Un fichier supprime est-il vraiment parti ? Que revele-t-il (un chemin, un endpoint oublie) ?
2. **Code cote client** : le bundle JS minifie n'est pas la source. Qu'est-ce qui permettrait de reconstruire la source d'origine, et que contient-elle (routes cachees, constantes) ?
3. **API moderne** : une API expose parfois son propre schema a qui sait le demander. Et certaines portes ne s'ouvrent qu'avec le bon nom d'hote.

Indices (maigres, volontairement)

- Indice 1 : `git` cote serveur.
- Indice 2 : source map (`.map`).
- Indice 3 : introspection, et en-tete `Host`.

Outils conseilles

`ffuf` / `feroxbuster` (liste ciblée), `git-dumper`, introspection GraphQL (ou `curl`), Burp Suite, `jq`, DevTools (onglets Sources et Réseau).

Livrable attendu

`carte-surface-attaque.md` : technologies, endpoints et COMMENT trouves, vhosts, artefacts exposes, et surtout la **chaîne complete** menant a chaque fragment. Puis le flag reconstitue.

Note

Si vous bloquez plus de 20 min sur une chaîne, documentez ce que vous avez testé. La méthode (recon systematique, lecture d'artefacts, correlation) vaut plus que la chance.